

Master Program

Cyber Security

Chapter 2 – Threats, Risks, Vulnerabilities

Defining Key words

Asset ?

Threat ?

Vulnerability ?

Risk ?

Why is it important to understand the difference between these terms?

If you don't understand the difference, you'll never understand the true risk to assets.

Asset

An asset is what we're trying to protect.

- *In **Cyber Security**, we can consider the infrastructure assets*
 - (A) equipment that is integral to research and education capabilities in cybersecurity, including, but not limited to--
 - (i) encryption devices;
 - (ii) network switches;
 - (iii) routers;
 - (iv) firewalls;
 - (v) wireless networking gear;
 - (vi) protocol analyzers;
 - (vii) file servers;
 - (viii) workstations;
 - (ix) biometric tools; and
 - (x) computers; and
 - (B) technology support staff (including graduate students) that is integral to research and education capabilities in cybersecurity.”

Threat

A threat is what we're trying to protect against.

Example: An intruder can exploit the password weakness to break into the system

Threat agent---entity that would knowingly seek to manifest a threat

Examples of Threats

Threats

- angry employees
- dishonest employees
- criminals
- governments
- terrorists
- the press
- competitors
- hackers
- nature

Security Threats

- ▶ According to ITSecurity.com the following are ten of the biggest network threats:
- ▶ "1. Viruses and Worms",
- ▶ "2. Trojan Horses",
- ▶ "3. SPAM",
- ▶ "4. Phishing",
- ▶ "5. Packet Sniffers",
- ▶ "6. Maliciously Coded Websites",
- ▶ "7. Password Attacks",
- ▶ "8. Hardware Loss and Residual Data Fragments",
- ▶ "9. Shared Computers",
- ▶ "10. Zombie Computers and Botnets" (ITSecurity [2], 2007)



Viruses, Worms, Trojans, Rootkits

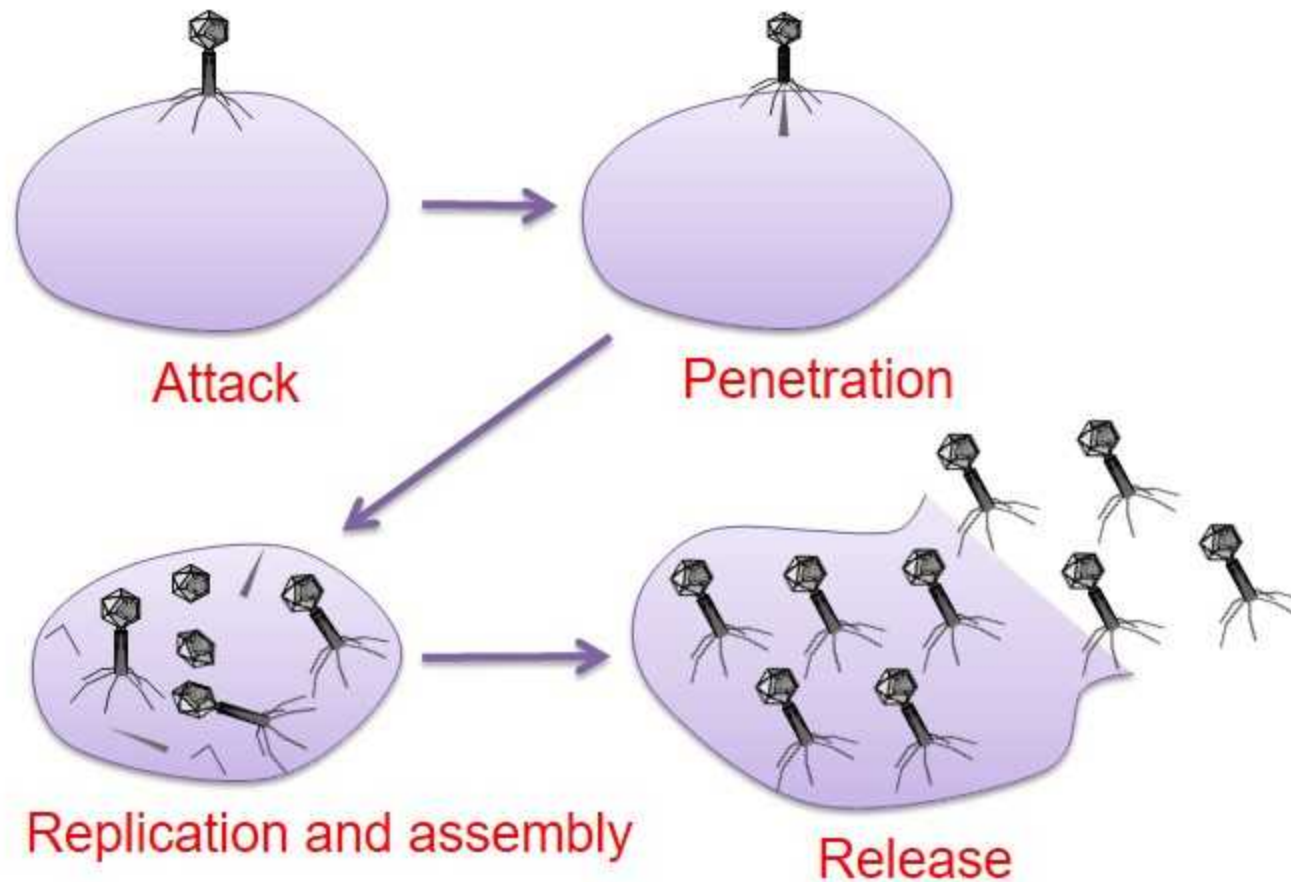
- **Malware** can be classified into several categories, depending on propagation and concealment
- Propagation
 - **Virus**: human-assisted propagation (e.g., open email attachment)
 - **Worm**: automatic propagation without human assistance
- Concealment
 - **Rootkit**: modifies operating system to hide its existence
 - **Trojan**: provides desirable functionality but hides malicious operation
- Various types of payloads, ranging from annoyance to crime

Computer Viruses

- A **computer virus** is computer code that can replicate itself by modifying other files or programs to insert code that is capable of further replication.
- This self-replication property is what distinguishes computer viruses from other kinds of malware, such as logic bombs.
- Another distinguishing property of a virus is that replication requires some type of **user assistance**, such as clicking on an email attachment or sharing a USB drive.

Biological Analogy

- Computer viruses share some properties with Biological viruses



Virus Phases

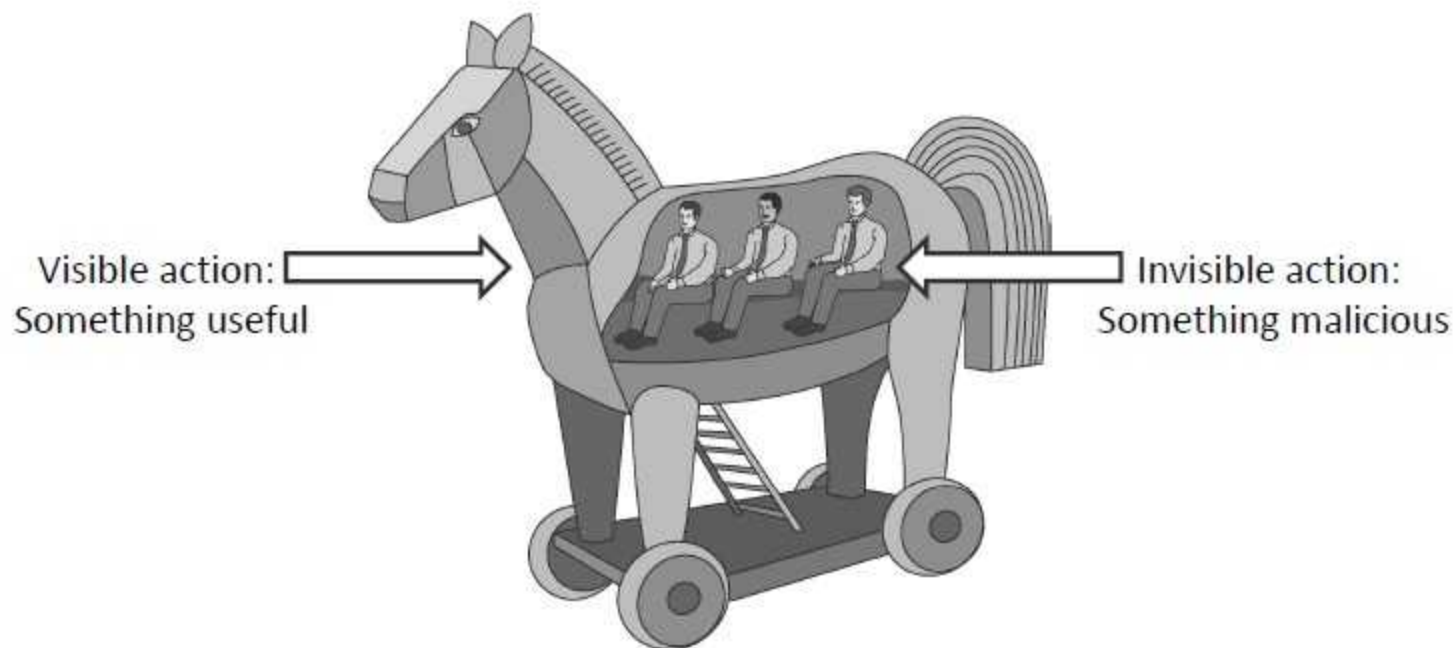
- **Dormant phase.** During this phase, the virus just exists—the virus is laying low and avoiding detection.
- **Propagation phase.** During this phase, the virus is replicating itself, infecting new files on new systems.
- **Triggering phase.** In this phase, some logical condition causes the virus to move from a dormant or propagation phase to perform its intended action.
- **Action phase.** In this phase, the virus performs the malicious action that it was designed to perform, called **payload**.
 - This action could include something seemingly innocent, like displaying a silly picture on a computer's screen, or something quite malicious, such as deleting all essential files on the hard drive.

Computer Worms

- A **computer worm** is a malware program that spreads copies of itself without the need to inject itself in other programs, and usually without human interaction.
- Thus, computer worms are technically not computer viruses (since they don't infect other programs), but some people nevertheless confuse the terms, since both spread by self-replication.
- In most cases, a computer worm will carry a malicious payload, such as deleting files or installing a backdoor.

Trojan Horses

- A **Trojan horse (or Trojan)** is a malware program that appears to perform some useful task, but which also does something with negative consequences (e.g., launches a keylogger).
- Trojan horses can be installed as part of the payload of other malware but are often installed by a user or administrator, either deliberately or accidentally.

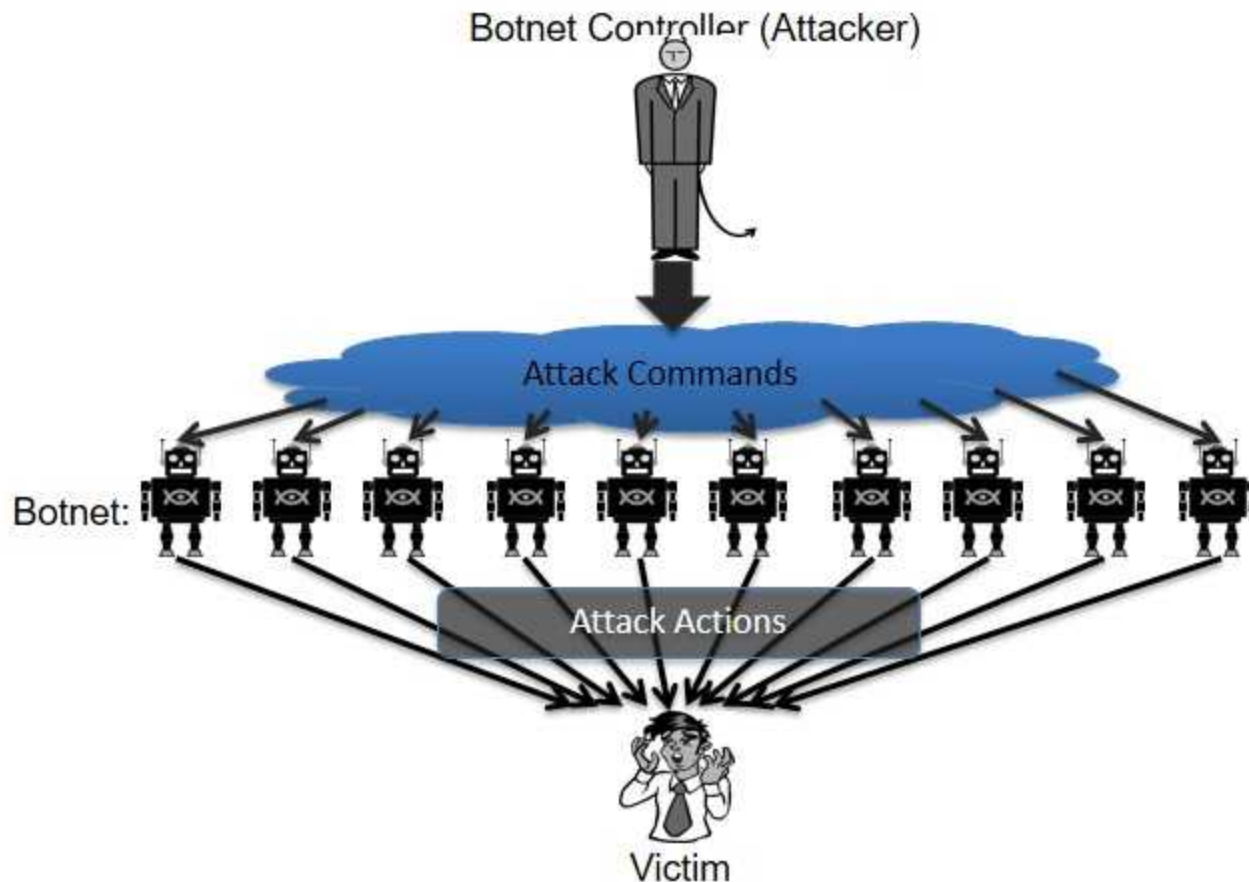


Rootkits

- A rootkit modifies the operating system to hide its existence
 - E.g., modifies file system exploration utilities
 - Hard to detect using software that relies on the OS itself
- RootkitRevealer
 - By Bryce Cogswell and Mark Russinovich (Sysinternals)
 - Two scans of file system
 - High-level scan using the Windows API
 - Raw scan using disk access methods
 - Discrepancy reveals presence of rootkit
 - Could be defeated by rootkit that intercepts and modifies results of raw scan operations

Malware Zombies

- Malware can turn a computer in to a **zombie**, which is a machine that is controlled externally to perform malicious attacks, usually as a part of a **botnet**.



Adware

Adware software payload



Adware engine infects
a user's computer

Computer user



Advertisers contract with
adware agent for content



Advertisers

Adware engine requests
advertisements
from adware agent



Adware agent

Adware agent delivers
ad content to user



Spyware

Spyware software payload



1. Spyware engine infects a user's computer.

Computer user



2. Spyware process collects keystrokes, passwords, and screen captures.

3. Spyware process periodically sends collected data to spyware data collection agent.



Spyware data collection agent

Quarantine

- A suspicious file can be isolated in a folder called **quarantine**:
 - E.g., if the result of the heuristic analysis is positive and you are waiting for db signatures update
- The suspicious file is not deleted but made harmless: the user can decide when to remove it or eventually restore for a false positive
 - Interacting with a file in quarantine it is possible only through the antivirus program
- The file in quarantine is harmless because it is encrypted
- Usually the quarantine technique is proprietary and the details are kept secret

Vulnerability

- Vulnerability – Weaknesses or gaps in a security program that can be exploited by threats to gain unauthorized access to an asset.
- *A vulnerability is a weakness or gap in our protection efforts.*

Example: password is vulnerable for dictionary or exhaustive key attacks

Types of vulnerabilities

- “Some weakness of a system that could allow security to be allowed.”
- Types of vulnerabilities
 - Physical vulnerabilities
 - Natural vulnerabilities
 - Hardware/software vulnerabilities
 - Media vulnerabilities (e.g., stolen/damaged disk/tapes)
 - Emanation vulnerabilities---due to radiation
 - Communication vulnerabilities
 - Human vulnerabilities

Examples of Vulnerability

- Ref: <http://simplicable.com/new/the-big-list-of-information-security-vulnerabilities>
- Information security vulnerabilities are weaknesses that expose an organization to risk.
- **Through employees:** Social interaction, Customer interaction, Discussing work in public locations, Taking data out of the office (paper, mobile phones, laptops), Emailing documents and data, Mailing and faxing documents, Installing unauthorized software and apps, Removing or disabling security tools, Letting unauthorized persons into the office (tailgating) , Opening spam emails, Connecting personal devices to company networks, Writing down passwords and sensitive data, Losing security devices such as id cards, Lack of information security awareness, Keying data
- Through former employees---Former employees working for competitors, Former employees retaining company data, Former employees discussing company matters
- Through Technology---Social networking, File sharing, Rapid technological changes, Legacy systems, Storing data on mobile devices such as mobile phones, Internet browsers
- Through hardware---. Susceptibility to dust, heat and humidity, Hardware design flaws, Out of date hardware, Misconfiguration of hardware

Examples of Vulnerability (2)

- Through software---Insufficient testing, Lack of audit trail, Software bugs and design faults, Unchecked user input, Software that fails to consider human factors, Software complexity (bloatware), Software as a service (relinquishing control of data), Software vendors that go out of business or change ownership
- Through Network---Unprotected network communications, Open physical connections, IPs and ports, Insecure network architecture, Unused user ids, Excessive privileges, Unnecessary jobs and scripts executing , Wifi networks
- Through IT Management---Insufficient IT capacity , Missed security patches, Insufficient incident and problem management, Configuration errors and missed security notices , System operation errors, Lack of regular audits, Improper waste disposal, Insufficient change management, Business process flaws, Inadequate business rules, Inadequate business controls, Processes that fail to consider human factors, Overconfidence in security audits, Lack of risk analysis, Rapid business change, Inadequate continuity planning Lax recruiting processes
- Partners and suppliers---Disruption of telecom services, Disruption of utility services such as electric, gas, water, Hardware failure, Software failure, Lost mail and courier packages, Supply disruptions, Sharing confidential data with partners and suppliers

How do the vulnerabilities manifest?

- The different types of vulnerabilities manifest themselves via several misuses:
 - External misuse---visual spying, misrepresenting, physical scavenging
 - Hardware misuse---logical scavenging, eavesdropping, interference, physical attack, physical removal
 - Masquerading---impersonation, piggybacking attack, spoofing attacks, network weaving
 - Pest programs---Trojan horse attacks, logic bombs, malevolent worms, virus attacks
 - Bypasses---Trapdoor attacks, authorization attacks (e.g., password cracking)
 - Active misuse---basic active attack, incremental attack, denial of service
 - Passive misuse---browsing, interference, aggregation, covert channels

"Threat Matrix" Sample

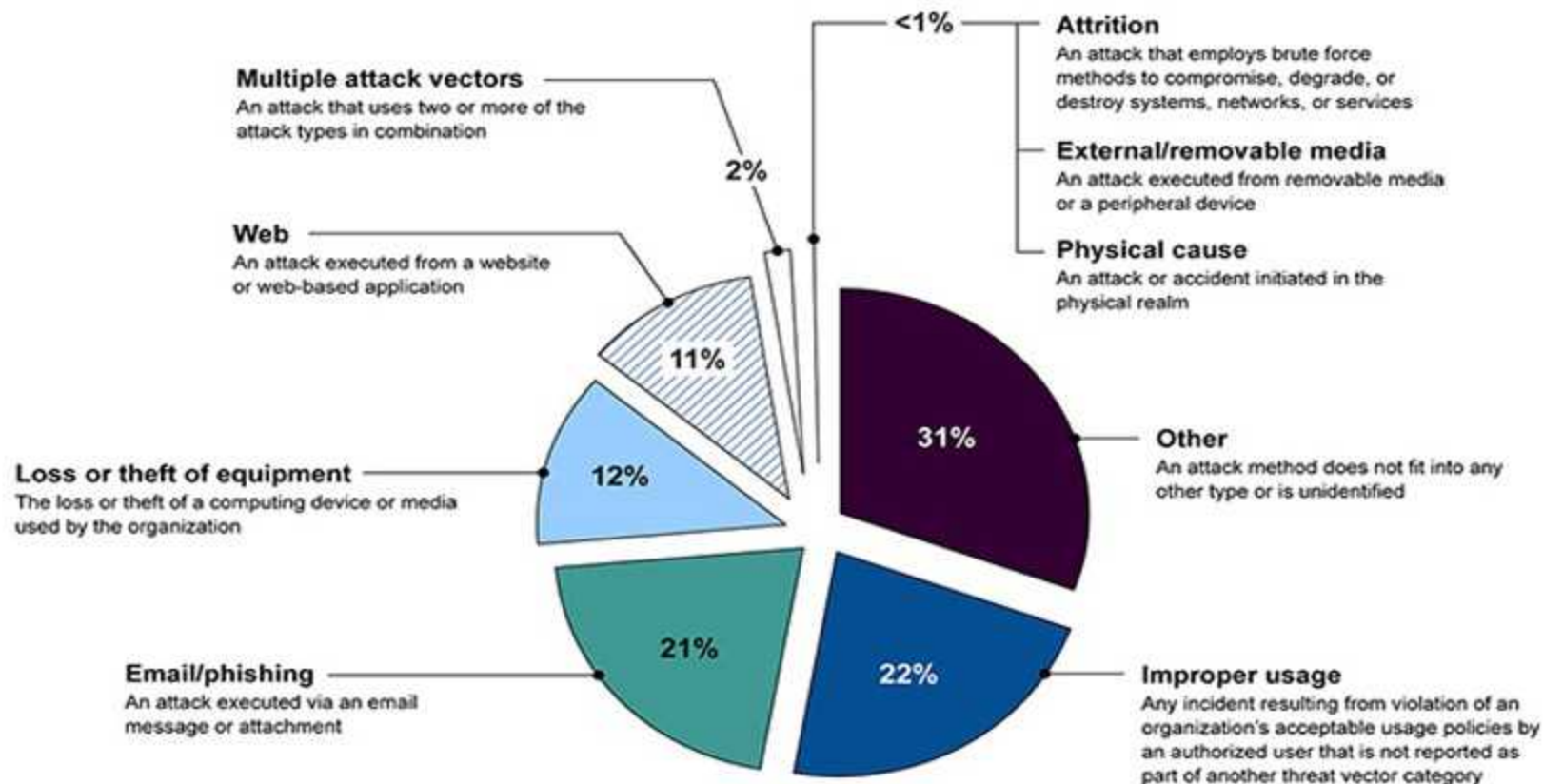
Threat Matrix							
<u>Threats</u> \ <u>Vulnerabilities</u>	Firewalls	Databases	Application Architecture	Physical Security	Insecure Wireless	Internet-based service (Like VPN)	Total Score
<i>Intrusion (Hacking, Password Attacks)</i>	9	3	9	9	9	3	42
<i>Insider Attacks</i>	3	3	3	9	3	1	22
<i>DDoS</i>	9	0	9	1	3	3	25
<i>Theft of Hardware</i>	1	1	1	9	3	1	16

Risk

- Risk – The potential for loss, damage or destruction of an asset as a result of a threat exploiting a vulnerability.
- *Risk is the intersection of assets, threats, and vulnerabilities.*
- *Example: the resources within the system are prone for illegal access/modify/damage by the intruder.*

Security incidents

35,277 total information security incidents



Source: GAO analysis of United States Computer Emergency Readiness Team and Office of Management and Budget data for fiscal year 2017. | GAO-18-622

Illustration (1)

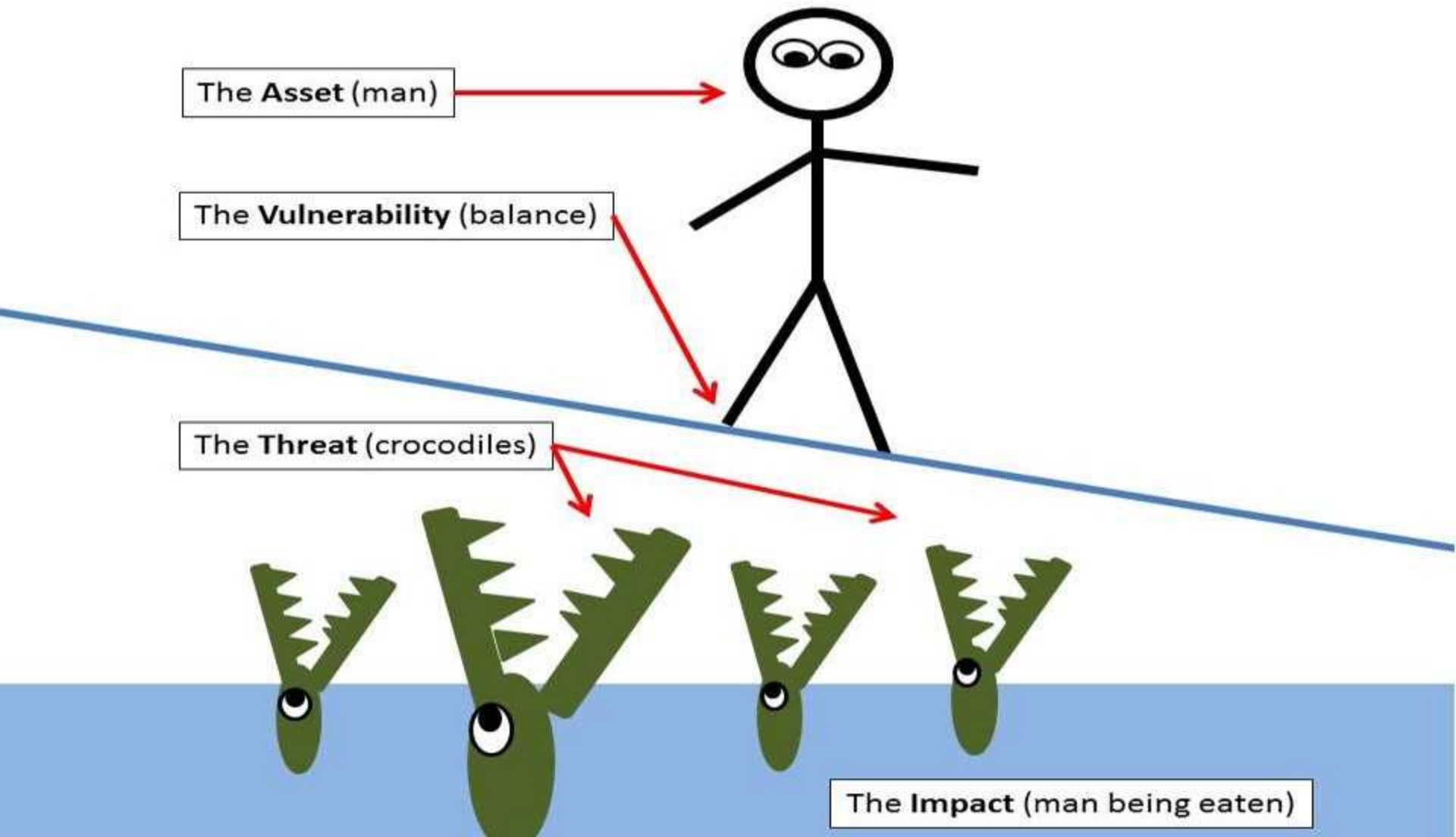
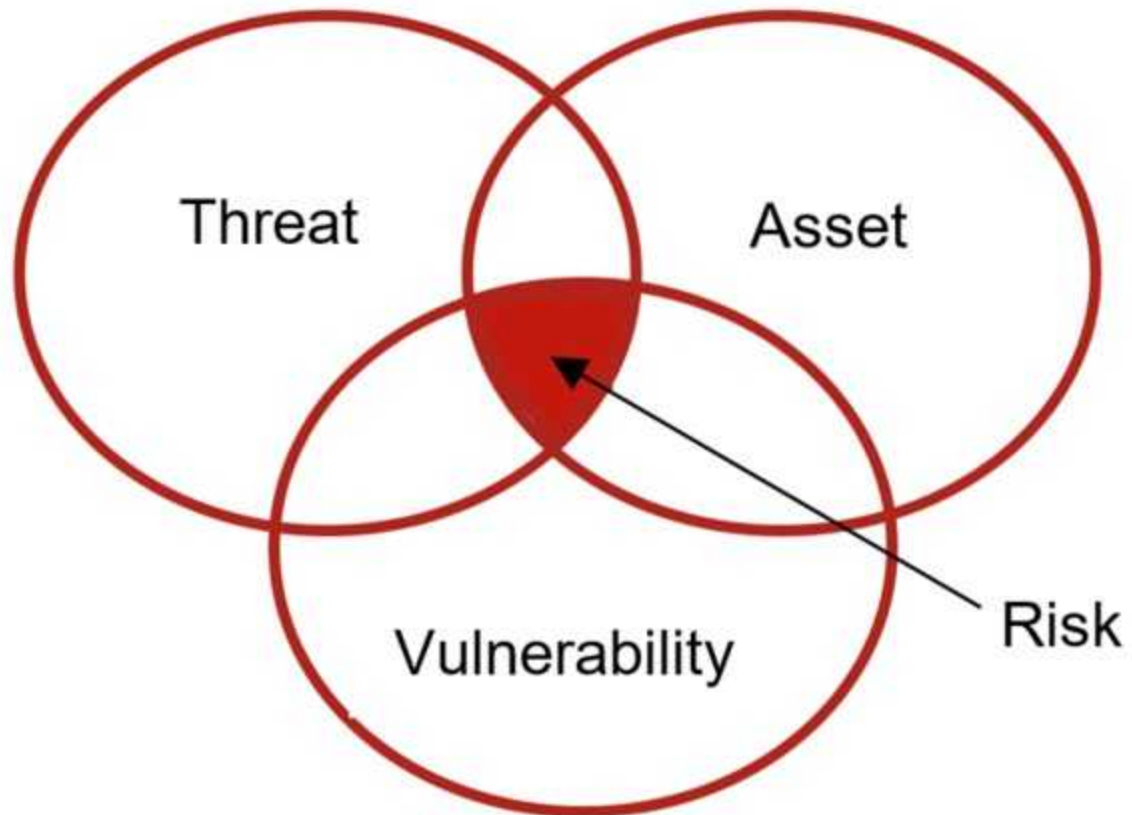
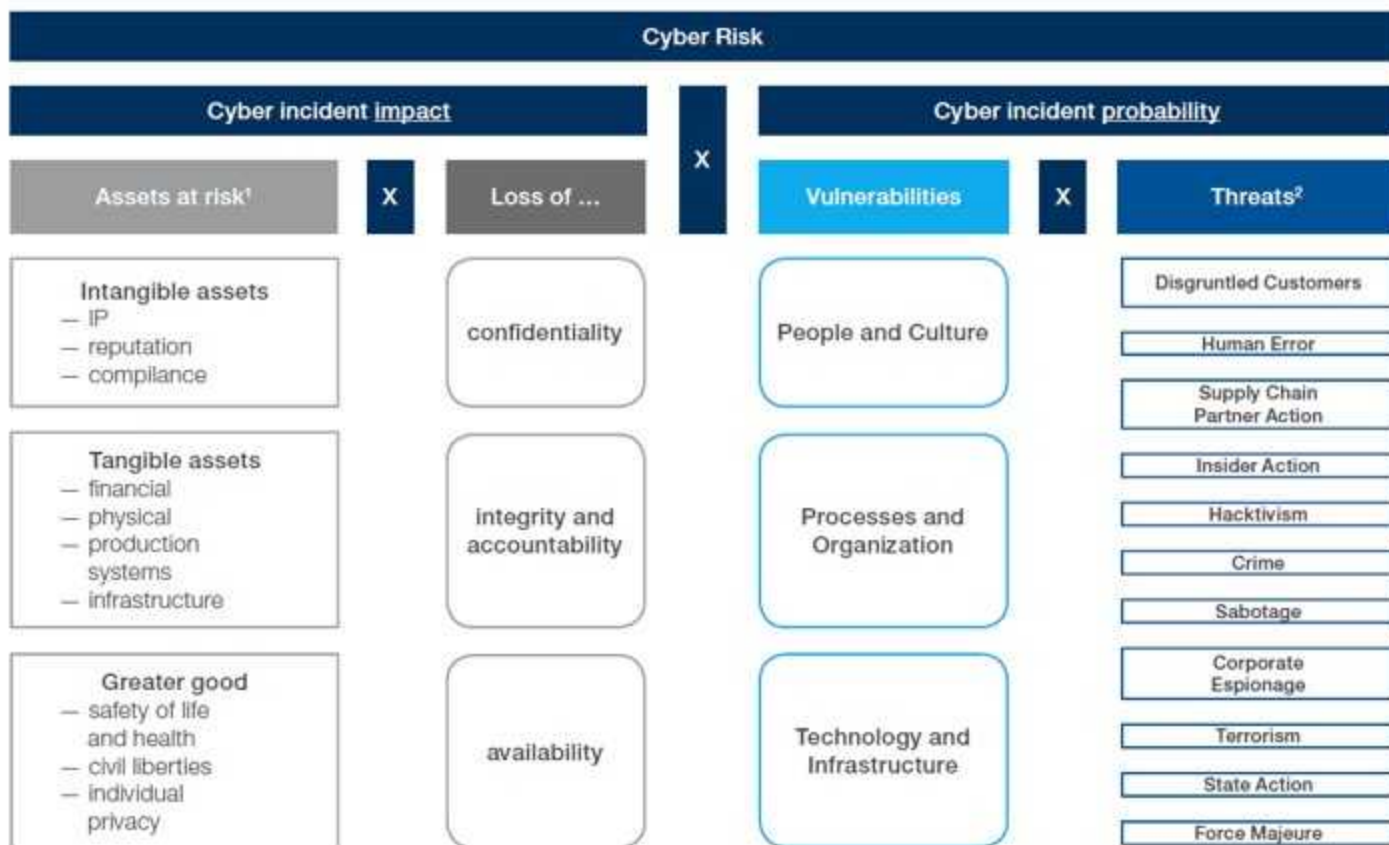


Illustration (2)



Cyber Risk Framework



¹ Examples for assets

² Selection of examples, sorted in ascending order of available resources